

Activity: Web Security Vulnerabilities – Analysis, Demonstration, and Mitigation

In this activity, students will work in groups to **analyze, demonstrate, and secure web applications** against common vulnerabilities. Each group will be assigned (or may choose) one or more vulnerabilities and will present a **working proof-of-concept (PoC)** along with **secure implementation practices**.

This activity emphasizes **real-world security awareness, secure coding, and defensive programming techniques**.

Assigned Vulnerabilities (refer to your groupings bellow)

1. CARRIAGE RETURN AND LINE FEED (CRLF) INJECTION
2. CIPHER TRANSFORMATION INSECURE
3. CROSS-ORIGIN RESOURCE SHARING (CORS) POLICY
4. CROSS-SITE REQUEST FORGERY (CSRF)
5. CROSS-SITE SCRIPTING (XSS)
6. DIRECTORY INDEXING and DIRECTORY TRAVERSAL

Task Requirements:

Conceptual Discussion

Explain clearly:

- What the vulnerability is
- How it works (technical explanation)
- Why it is dangerous
- Real-world example or case

Demonstration (PoC)

Create a **working demo** using:

- Laravel / Node.js / PHP / any web framework
- Localhost environment (e.g., XAMPP, Docker, etc.)

Must include:

- Vulnerable version (before fix)
- Attack simulation (e.g., payload, request manipulation)
- Proof that the attack works

Ethical note: Only test in controlled/local environments.

Prevention / Mitigation

Show **secure implementation**:

- Code-level fixes
- Framework-based protections (middleware, validation, etc.)
- Security best practices

Examples:

- Input validation / sanitization
- Secure headers
- Token-based protection
- Dependency updates

Documentation

Submit a **PDF Documentation** including:

- Title page
- Group members
- Vulnerability explanation
- Screenshots of attack
- Code snippets (before & after)
- Mitigation explanation
- References

Presentation & Demo

Each group must:

- Presentation (5minutes)
- Perform live demo (10 minutes)
- Answer questions

RUBRIC

Criteria (100 POINTS)	Excellent (Full Points)	Good	Fair	Poor	SCORE
Understanding of Vulnerability (15 POINTS)	Clear, deep, technically accurate, with real-world context	Mostly clear with minor gaps	Basic explanation only	Misunderstood concept	
Demonstration (PoC) (20 POINTS)	Fully working, realistic attack with clear proof	Works but lacks depth	Partial / inconsistent demo	No working demo	
Technical Implementation (15 POINTS)	Clean, well-structured, realistic system	Functional but minor issues	Basic implementation	Poor or incomplete	
Mitigation & Security Fixes (20 POINTS)	Strong, correct, industry-level fixes	Correct but limited depth	Basic fixes only	Incorrect or missing	
Documentation (10 POINTS)	Complete, well-organized, professional	Minor missing details	Lacks clarity/structure	Incomplete	
Presentation & Delivery (10 POINTS)	Clear, confident, engaging demo	Understandable presentation	Some confusion	Poor delivery	
Depth of Analysis (10 POINTS)	Insightful analysis, risks, improvements	Some analysis	Minimal analysis	No analysis	
TOTAL					